Contents

Harbor Goods: GenAI architecture, security and cost review **1**
1. Executive summary . . . 1
Top three recommendations . . . 2
2. Scope and method . . . 2
3. Architecture reviewed . . . 3
4. Findings . . . 3
4.1 Security . . . 4
4.2 Cost optimization . . . 5
4.3 Operational excellence . . . 6
4.4 Other pillars . . . 7
5. Cost model . . . 7
5.1 By component . . . 7
5.2 By lever . . . 7
6. Fixes delivered . . . 8
Roadmap . . . 8
7. Generative AI Lens coverage . . . 9
8. Evidence register . . . 10
9. Limits . . . 11

Harbor Goods: GenAI architecture, security and cost review

> **Fictional sample.** Harbor Goods and all data here are fictional. Each repository in this portfolio is a separate engagement with Harbor Goods, a fictional mid-size retailer. Account IDs are shown as placeholders. Every finding and figure in this report comes from the files in `data/`.

Item	Detail
Client	Harbor Goods (fictional mid-size retailer)
Workload	`product-assistant`: customer-facing product Q&A assistant on Amazon Bedrock
Accounts	Production, staging and shared tooling, each shown as `<account-id>`
Region	`us-east-1`
Lens	AWS Well-Architected Generative AI Lens
Access used	Read-only exports, reviewed offline; no changes to the client's accounts
Revision	1.0

Tables between `BEGIN GENERATED` and `END GENERATED` markers in the source come from `make evidence` and the data. The tests in `tests/` recompute them independently.

1. Executive summary

The product team shipped the assistant quickly, and shoppers use it. Three concerns brought the review: the Bedrock bill grows every month, the security team asked about prompt injection and personal data in logs, and nobody measures answer quality before a change ships.

All three have concrete causes. Every route runs the largest model, pays full price for the same system prompt on every request, and keeps a vector store sized for far more data than it holds. One of the two interactive routes has no guardrail, the function role can do anything in Bedrock, raw prompts with phone numbers land in logs that never expire, and the API has no throttling. The foundations are sound: the stack is serverless and in Terraform, calls already use a cross-Region inference profile, responses have a length cap, and the prompts have version control.

17 Generative AI Lens best practices reviewed, 6 met. 11 findings: 3 high, 6 medium and 2 low risk. The recommended changes take the modeled monthly bill from $22,225.91 to $9,590.74 ($12,635.17 less, 57%), after paying for the added guardrail coverage and invocation logging.

Measure	Value
Best practices reviewed (met)	17 (6)
Findings (high, medium, low)	11 (3, 6, 2)
Scripted checks (passed)	13 (2)
GenAI spend, month-1 to month-3 (CUR)	$16,629.38 to $22,295.21 (+34%)
Modeled monthly cost as found	$22,225.91
Modeled monthly cost after the fixes	$9,590.74
Monthly difference	-$12,635.17 (-57%)
Model reconciliation with the latest CUR month	within 0.3%

Top three recommendations

1. **The Lambda role allows `bedrock:*` on every resource** (GENSEC01-BP01, High risk, effort S). Replace the statement with bedrock:InvokeModel and bedrock:InvokeModelWithResponseStream on the three application inference profiles and their foundation models, bedrock:ApplyGuardrail on the guardrail, bedrock:Retrieve on the knowledge base, and the batch inference actions for the enrich job only.
2. **Application logs keep customer prompts with personal data, unencrypted and forever** (GENSEC04-BP02, High risk, effort M). Stop logging raw prompts (log token counts and request IDs), redact PII in the handler before any log call, anonymize PII in the guardrail, and encrypt the log groups with a customer managed KMS key and a retention period.
3. **The compare route calls the model with no guardrail** (GENSEC02-BP01, High risk, effort S). Attach one versioned guardrail to every route: prompt-attack and content filters, the denied competitor-pricing topic, and PII anonymization on input and output. Call it through guardrailConfig on each Converse request.

Every finding comes with the change that closes it, in `fixes/`: Terraform for the account-level controls, and application code for the request path, the batch job and the release gate. Section 6 maps each file to the findings it closes.

2. Scope and method

The review covered one workload, `product-assistant`: the API layer, three Lambda functions (`ask`, `compare` and the nightly `enrich` job), their IAM role, Amazon Bedrock models, guardrails and the knowledge base, the vector store, chat history, application logs, the deployment pipeline, and the GenAI line items of the bill. The storefront web tier, the orders database, penetration testing and model fine-tuning were out of scope.

The review followed the method in `docs/methodology.md`:

1. A scoping call agreed the workload, the Generative AI Lens best practices in scope and read-only exports.
2. The client exported the Terraform state, the function role, the Bedrock account settings, a log sample, the pipeline definition and three months of cost and usage data (section 8 lists them).
3. The review team and the product team agreed a golden set of questions, and the review ran it against three models offline.
4. Scripted checks in `scripts/genai_review/checks.py` read the exports and decide each best practice that has a check. The interview confirmed the remaining best practices, recorded with their evidence.
5. Each failed check became a finding with a risk rating, an effort estimate, an owner and a fix, and the cost model priced the as-found state and the state after the fixes from the same traffic figures.

Risk ratings follow the likely impact on shoppers and on Harbor Goods if the gap stays open: high for exposure of customer data or uncontrolled access, medium for gaps that cost money or quality every day, low for gaps that only limit visibility or efficiency. The ranking orders findings by risk, then by monthly saving, then by effort.

3. Architecture reviewed

Shoppers reach the assistant from the storefront chat widget, the mobile app and store kiosks through Amazon CloudFront (with AWS WAF) and an Amazon API Gateway REST API, signed in with Amazon Cognito. Three Lambda functions share one IAM role.

Component	As found
`ask` function	Product questions; Claude Sonnet 4.5 through the `us.` cross-Region profile; guardrail with a prompt-attack filter and one denied topic
`compare` function	Side-by-side comparisons; Claude Sonnet 4.5; no guardrail
`enrich` function	Nightly rewrite of catalog descriptions; Claude Sonnet 4.5 on-demand
Knowledge base	Bedrock Knowledge Bases over an OpenSearch Serverless vector collection with standby replicas
Chat history	DynamoDB on-demand with a TTL
Logs	CloudWatch Logs per function; raw prompts logged, no KMS key, two groups never expire
Pipeline	Lint, unit tests, package, deploy to staging, deploy to production after manual approval

4. Findings

Key	Risk	Best practice	Finding	Effort	Monthly cost change
GA-01	High	GENSEC01-BP01	The Lambda role allows `bedrock:*` on every resource	S	-
GA-02	High	GENSEC04-BP02	Application logs keep customer prompts with personal data, unencrypted and forever	M	-
GA-03	High	GENSEC02-BP01	The compare route calls the model with no guardrail	S	+$360.00
GA-04	Medium	GENCOST01-BP01	The ask route uses Claude Sonnet where Claude Haiku meets the quality bar	S	-$10,909.80
GA-05	Medium	GENCOST03-BP03	Every interactive request pays full price for the 2,400-token system prompt	S	-$1,000.89

Key	Risk	Best practice	Finding	Effort	Monthly cost change
GA-06	Medium	GENCOST02-BP02	The knowledge base keeps 4 OpenSearch Serverless OCUs running for 2 GB of vectors	M	-$689.65
GA-07	Medium	GENOPS02-BP03	The API has no throttling and no per-channel quota	M	-
GA-08	Medium	GENOPS01-BP01	No evaluation runs before a prompt or model change reaches production	M	-
GA-09	Medium	GENSEC03-BP01	Model invocation logging is off	S	+$1.18
GA-10	Low	GENCOST02-BP01	The nightly enrich job uses on-demand inference	M	-$396.00
GA-11	Low	GENOPS02-BP02	The bill cannot show model usage by route or cost center	S	-

Each finding below names the Generative AI Lens best practice, what the checks observed, the risk if the gap stays open, the change that closes it, and the file in `fixes/` that implements the change.

4.1 Security

GA-01. The Lambda role allows `bedrock:*` on every resource *GENSEC01-BP01 Grant scoped access to foundation model endpoints.* High risk, effort S, owner: Platform team, Weeks 1-2.

- **Observed:** assistant-runtime/Bedrock allows `bedrock:*` on `*` (EV-02).
- **Risk if left open:** Any code running in the three functions can create or delete guardrails, knowledge bases and model access, change invocation logging, or call any model in any Region.
- **Recommendation:** Replace the statement with bedrock:InvokeModel and bedrock:InvokeModelWithResponseStream on the three application inference profiles and their foundation models, bedrock:ApplyGuardrail on the guardrail, bedrock:Retrieve on the knowledge base, and the batch inference actions for the enrich job only.
- **Fix delivered:** `fixes/terraform/iam.tf`.

GA-02. Application logs keep customer prompts with personal data, unencrypted and forever *GENSEC04-BP02 Sanitize and validate user inputs to foundation models.* High risk, effort M, owner: Product engineering, Weeks 1-2.

- **Observed:** 8 sampled log events hold 1 loyalty card number and 2 phone numbers; 3 of 3 log groups have no KMS key and 2 never expire (EV-01, EV-04).
- **Risk if left open:** Phone numbers and loyalty card numbers from shoppers sit in CloudWatch Logs in clear text with no expiry, which widens the data a leaked log or an over-broad log reader exposes.

- **Recommendation:** Stop logging raw prompts (log token counts and request IDs), redact PII in the handler before any log call, anonymize PII in the guardrail, and encrypt the log groups with a customer managed KMS key and a retention period.
- **Fix delivered:** `fixes/app/assistant.py`, `fixes/terraform/logging.tf`, `fixes/terraform/guardrail.tf`.

GA-03. The compare route calls the model with no guardrail *GENSEC02-BP01 Implement guardrails to mitigate harmful or incorrect model responses.* High risk, effort S, owner: Platform team, Weeks 1-2.

- **Observed:** GUARDRAIL_ID is empty on: compare (EV-01, EV-03, EV-04).
- **Risk if left open:** Prompt injection and off-topic or harmful answers on the compare route reach shoppers unfiltered. The log sample holds an injection attempt against that route.
- **Recommendation:** Attach one versioned guardrail to every route: prompt-attack and content filters, the denied competitor-pricing topic, and PII anonymization on input and output. Call it through guardrailConfig on each Converse request.
- **Fix delivered:** `fixes/terraform/guardrail.tf`, `fixes/app/assistant.py`.
- **Monthly cost change:** +$360.00.

GA-09. Model invocation logging is off *GENSEC03-BP01 Implement control plane and data access monitoring to generative AI services and foundation models.* Medium risk, effort S, owner: Platform team, Weeks 3-6.

- **Observed:** get-model-invocation-logging-configuration returns no loggingConfig (EV-03).
- **Risk if left open:** Nobody can audit which identity called which model and when, or attribute token use to a route and a caller.
- **Recommendation:** Enable Bedrock model invocation logging to a KMS-encrypted CloudWatch Logs group with one-year retention, with text data delivery off so each record holds the request metadata and token counts only. Bedrock logs the original input even when the guardrail anonymizes PII, so text delivery would copy raw prompts into the logs.
- **Fix delivered:** `fixes/terraform/logging.tf`.
- **Monthly cost change:** +$1.18.

4.2 Cost optimization

GA-04. The ask route uses Claude Sonnet where Claude Haiku meets the quality bar *GENCOST01-BP01 Right-size model selection to optimize inference costs.* Medium risk, effort S, owner: Product engineering, Weeks 3-6.

- **Observed:** ask uses claude-sonnet; claude-haiku passes 93.6% overall, 90% in its weakest category (EV-05, EV-06).
- **Risk if left open:** The ask route carries most of the token spend and pays for capability its questions do not need.
- **Recommendation:** Move the ask route to Claude Haiku through its application inference profile once the evaluation stage is in the pipeline. Keep Claude Sonnet on compare, where Haiku falls below the bar. On Claude Haiku the ask route's 2,400-token system prompt is below the 4,096-token cache minimum, so that route gets no caching saving.
- **Fix delivered:** `fixes/terraform/inference_profiles.tf`.
- **Monthly cost change:** -$10,909.80.
- **Depends on:** GA-08, GA-11.

GA-05. Every interactive request pays full price for the 2,400-token system prompt *GENCOST03-BP03 Implement prompt caching to reduce token costs.* Medium risk, effort S, owner: Product engineering, Weeks 3-6.

- **Observed:** PROMPT_CACHING is off on ask, compare (system prompt tokens: ask 2,400, compare 2,400) (EV-01, EV-08).
- **Risk if left open:** The static system prompt is more than 40% of every interactive request's input tokens.

- **Recommendation:** Put a cache point after the system prompt on each route whose prompt reaches the model's minimum cacheable length: 1,024 tokens for Claude Sonnet 4.5, 4,096 for Claude Haiku 4.5. That is the compare route; once the ask route moves to Claude Haiku its 2,400-token prompt is below the minimum, so it gets no cache point.
- **Fix delivered:** `fixes/app/assistant.py`.
- **Monthly cost change:** -$1,000.89.

GA-06. The knowledge base keeps 4 OpenSearch Serverless OCUs running for 2 GB of vectors *GENCOST02-BP02 Optimize resource consumption to minimize hosting costs.* Medium risk, effort M, owner: Platform team, Weeks 3-6.

- **Observed:** 4 OCUs on average for 2 GB of vector data (EV-01, EV-03, EV-06).
- **Risk if left open:** The vector store costs a fixed amount every hour whatever the traffic, for an index that fits in a few gigabytes.
- **Recommendation:** Move the knowledge base to Amazon S3 Vectors, re-ingest, compare retrieval on the golden set, then delete the collection.
- **Fix delivered:** `fixes/terraform/vectors.tf`.
- **Monthly cost change:** -$689.65.
- **Depends on:** GA-08.

GA-10. The nightly enrich job uses on-demand inference *GENCOST02-BP01 Balance cost and performance when selecting inference paradigms.* Low risk, effort M, owner: Product engineering, Weeks 7-10.

- **Observed:** offline routes on on-demand inference: enrich (EV-01, EV-08).
- **Risk if left open:** The job has no latency need but pays the on-demand price for every token.
- **Recommendation:** Submit the nightly descriptions as one Bedrock batch inference job from S3 and read the results back in the morning run.
- **Fix delivered:** `fixes/app/enrich_batch.py`, `fixes/terraform/iam.tf`.
- **Monthly cost change:** -$396.00.

4.3 Operational excellence

GA-07. The API has no throttling and no per-channel quota *GENOPS02-BP03 Implement solutions to mitigate the risk of system overload.* Medium risk, effort M, owner: Platform team, Weeks 3-6.

- **Observed:** stage throttling unset (rate limit -1); 0 usage plans; 2 of 2 methods accept requests without an API key (EV-01).
- **Risk if left open:** One misbehaving client or scraper can exhaust the account's Bedrock tokens-per-minute quota for every channel and run up token spend with no ceiling.
- **Recommendation:** Set stage-level throttling and one usage plan per channel (web, mobile app, store kiosk) with rate, burst and daily quota, require an API key on the ask and compare methods (a usage plan only applies to methods that require one), and alarm when the 4XX rate climbs.
- **Fix delivered:** `fixes/terraform/throttling.tf`.

GA-08. No evaluation runs before a prompt or model change reaches production *GENOPS01-BP01 Periodically evaluate functional performance.* Medium risk, effort M, owner: Product engineering, Weeks 3-6.

- **Observed:** pipeline stages: lint, unit-test, package, deploy-staging, deploy-production (EV-05, EV-07).
- **Risk if left open:** A prompt edit or model switch can lower answer quality without anyone noticing until shoppers complain, and the team cannot adopt a cheaper model safely.
- **Recommendation:** Run the golden set in the pipeline between deploy-staging and deploy-production, and block the release when the pass rate falls under 90% overall or 85% in any category, or when the run misses a route, the shipping model, a category or part of its questions.
- **Fix delivered:** `fixes/pipeline/evaluate-stage.yaml`, `fixes/pipeline/golden-set.json`, `fixes/app/eval_gate.py`.

GA-11. The bill cannot show model usage by route or cost center *GENOPS02-BP02 Monitor foundation model metrics.* Low risk, effort S, owner: Platform team, Weeks 3-6.

- **Observed:** 0 application inference profiles for 3 routes (EV-03, EV-06).
- **Risk if left open:** The bill shows one line per model, so the team cannot see which route drives spend or set per-route budgets.
- **Recommendation:** Create one application inference profile per route, tagged with app, route and cost center, and invoke the model through its profile ARN.
- **Fix delivered:** `fixes/terraform/inference_profiles.tf`.

4.4 Other pillars

The reliability, performance efficiency and sustainability best practices in scope all hold; section 7 lists them with their evidence.

5. Cost model

The model prices one month of the workload twice from the same traffic: as found, and with every fix applied. Token counts per request come from the application's usage metrics; unit prices are in `data/pricing.yaml`. The as-found figure reconciles with the latest month of the cost and usage report, which confirms the traffic figures before the report claims any saving.

Billing period	Bedrock and OpenSearch Serverless (CUR)
month-1	$16,629.38
month-2	$19,212.40
month-3	$22,295.21

5.1 By component

Component	As found	After fixes	Change
ask route tokens	$16,364.70	$5,454.90	-$10,909.80
compare route tokens	$3,826.35	$2,825.46	-$1,000.89
enrich job tokens	$792.00	$396.00	-$396.00
embeddings	$2.06	$2.06	$0.00
guardrails	$540.00	$900.00	+$360.00
vector store	$700.80	$11.14	-$689.65
invocation logging	$0.00	$1.18	+$1.18
Total	**$22,225.91**	**$9,590.74**	**-$12,635.17**

5.2 By lever

The model prices each lever on top of the levers above it, so the figures add up to the net change. The order changes the split, not the total: once the ask route runs on Claude Haiku, caching saves nothing there, because its system prompt is below Haiku's minimum cacheable length.

Lever (applied in this order)	Finding	Monthly change
Right-size the ask route model	GA-04	-$10,909.80
Cache the system prompt where the model allows it	GA-05	-$1,000.89
Batch inference for the enrich job	GA-10	-$396.00
Move the knowledge base to S3 Vectors	GA-06	-$689.65

Lever (applied in this order)	Finding	Monthly change
Guardrail with PII filter on every route	GA-03	+$360.00
Model invocation logging	GA-09	+$1.18
Net change	-	**-$12,635.17**

Assumptions behind the recommended state, all in `data/synthetic/workload.yaml`:

- Token prices carry the 10% premium for geographic (`us.`) cross-Region inference profiles on Claude Sonnet 4.5 and Claude Haiku 4.5, as the Lambda functions call them; `data/pricing.yaml` cites the sources.
- A cache point only takes effect on a prompt prefix of at least the model's minimum: 1,024 tokens for Claude Sonnet 4.5, 4,096 for Claude Haiku 4.5. The 2,400-token system prompt is cached on the compare route (Sonnet) only; 95% of compare requests read it from the cache and the rest write it. The ask route on Haiku pays the full input price.
- The ask route moves to Claude Haiku 4.5, which passed the agreed bar on the golden set; compare stays on Claude Sonnet 4.5, where Haiku did not.
- The guardrail charges one text unit per 1,000 characters at four characters per token, on the shopper's question and on the answer, for each policy type.
- S3 Vectors query charges count the whole index as processed data on every query, which overstates them.
- Invocation logs carry metadata and token counts only (text data delivery off), about 2 KB per request, all routes included.

Two fixes add cost on purpose: guardrail coverage on the compare route with the PII filter, and invocation logging. They are the price of the security findings, and the net figure includes them.

6. Fixes delivered

File	Closes
`fixes/app/assistant.py`	GA-02, GA-03, GA-05
`fixes/app/enrich_batch.py`	GA-10
`fixes/app/eval_gate.py`	GA-08
`fixes/pipeline/evaluate-stage.yaml`	GA-08
`fixes/pipeline/golden-set.json`	GA-08
`fixes/terraform/guardrail.tf`	GA-02, GA-03
`fixes/terraform/iam.tf`	GA-01, GA-10
`fixes/terraform/inference_profiles.tf`	GA-04, GA-11
`fixes/terraform/logging.tf`	GA-02, GA-09
`fixes/terraform/throttling.tf`	GA-07
`fixes/terraform/vectors.tf`	GA-06

The Terraform in `fixes/terraform/` applies to the production account as one change. `terraform test` runs it against a mocked provider in CI and asserts the controls each finding needs; the client applies it through its own pipeline. The application files replace the request path of the ask and compare functions and the enrich job's inference call, and add the release gate; `tests/test_fixes_app.py` exercises them against a stubbed Bedrock client.

Roadmap

Phases follow risk. A fix that another fix depends on moves up to that fix's phase: the model switch waits for the evaluation stage and the inference profiles.

Phase	Findings (effort)
Weeks 1-2	GA-01 (S), GA-02 (M), GA-03 (S)
Weeks 3-6	GA-04 (S), GA-05 (S), GA-06 (M), GA-07 (M), GA-08 (M), GA-09 (S), GA-11 (S)
Weeks 7-10	GA-10 (M)

7. Generative AI Lens coverage

Best practice	Title	Status	Basis	Evidence
GENOPS01-BP01	Periodically evaluate functional performance	Not met	scripted check	EV-05, EV-07
GENOPS01-BP02	Collect and monitor user feedback	Met	interview and review	EV-08
GENOPS02-BP02	Monitor foundation model metrics	Not met	scripted check	EV-03, EV-06
GENOPS02-BP03	Implement solutions to mitigate the risk of system overload	Not met	scripted check	EV-01
GENOPS03-BP01	Implement prompt template management	Met	interview and review	EV-08
GENSEC01-BP01	Grant scoped access to foundation model endpoints	Not met	scripted check	EV-02
GENSEC02-BP01	Implement guardrails to mitigate harmful or incorrect model responses	Not met	scripted check	EV-01, EV-03, EV-04
GENSEC03-BP01	Implement control plane and data access monitoring to generative AI services and foundation models	Not met	scripted check	EV-03
GENSEC04-BP02	Sanitize and validate user inputs to foundation models	Not met	scripted check	EV-01, EV-04
GENREL01-BP01	Scale and balance foundation model throughput as a function of utilization	Met	scripted check	EV-01
GENPERF01-BP01	Define a ground truth data set of prompts and responses	Met	interview and review	EV-05, EV-08
GENCOST01-BP01	Right-size model selection to optimize inference costs	Not met	scripted check	EV-05, EV-06

Best practice	Title	Status	Basis	Evidence
GENCOST02-BP01	Balance cost and performance when selecting inference paradigms	Not met	scripted check	EV-01, EV-08
GENCOST02-BP02	Optimize resource consumption to minimize hosting costs	Not met	scripted check	EV-01, EV-03, EV-06
GENCOST03-BP02	Control model response length	Met	scripted check	EV-01
GENCOST03-BP03	Implement prompt caching to reduce token costs	Not met	scripted check	EV-01, EV-08
GENSUS01-BP01	Implement auto scaling and serverless architectures to optimize resource utilization	Met	interview and review	EV-01

8. Evidence register

ID	Evidence	Kind	File
EV-01	Terraform state export of the product-assistant stack	read-only export	`data/synthetic/as-found/terraform-`
EV-02	IAM role and inline policies of the Lambda functions	read-only export	`data/synthetic/as-found/iam-lambda`
EV-03	Bedrock account settings (invocation logging, inference profiles, guardrails, OCU limits)	read-only export	`data/synthetic/as-found/bedrock-se`
EV-04	Sample of application log events from the ask and compare functions	read-only export	`data/synthetic/as-found/app-log-sa`
EV-05	Offline evaluation of three models on the golden question set	review test	`data/synthetic/as-found/eval-resul`
EV-06	Cost and usage line items for Bedrock and OpenSearch Serverless, last three months	read-only export	`data/synthetic/as-found/cur-genai.`
EV-07	Deployment pipeline stages	read-only export	`data/synthetic/as-found/ci-pipelin`
EV-08	Interview with the product and platform team (prompts, feedback, scaling, traffic)	interview	`data/synthetic/workload.yaml`

9. Limits

- Harbor Goods, its traffic, logs, bill and evaluation results are fictional. The findings show the format and the reasoning, not the state of any real system.
- The golden set measures answer quality on the questions it contains. The model switch holds for the question mix it covers; the evaluation stage keeps measuring as the mix changes.
- Prices are list prices at the time of the review. The report is re-priced when it is re-issued.
- A review of the prompts' wording, red-team testing and a penetration test were out of scope.